



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Siemens SIPROTEC 5 Using DIGSI5 Protocol

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-06-23
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | Siemens SIPROTEC 5 Using DIGSI5 Protocol - CVE / Vulnerability Threat Intelligence Report

Published: 2026-06-23 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Affected Products and Exposure
7. Aviation / Aerospace Sector Impact
8. Mitigation and Workarounds
9. Detection Engineering
 - 9.1. Detection Logic Summary
10. Threat Hunting
 - 10.1. Hunt Hypothesis
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

Siemens SIPROTEC 5 Using DIGSI5 Protocol

1. Executive Summary

CISA published ICS advisory ICSA-26-174-02 for Siemens SIPROTEC 5 devices using the DIGSI 5 protocol. The advisory tracks CVE-2025-40808, an authenticated arbitrary file upload issue that can permit malicious configuration upload, create denial-of-service conditions, and may lead to code execution depending on device role and deployment context.

Defenders should prioritize this issue where SIPROTEC 5 protection relays are reachable from engineering workstations, remote maintenance zones, transportation-system substations, airport power-distribution environments, manufacturing sites, or energy control networks. The vulnerability requires authenticated access, but the operational impact is high because protection relays sit close to process continuity and safety outcomes.

2. Vulnerability Metadata

Field	Value
CVE	CVE-2025-40808
Vendor / Product	Siemens SIPROTEC 5 using DIGSI 5 protocol
Weakness	CWE-434 unrestricted upload of file with dangerous type
CVSS	CVSS v3.1 6.1 per CISA advisory
Affected Versions	Multiple SIPROTEC 5 CP050, CP100, CP150, CP200, and CP300 models listed by CISA / Siemens
Fixed / Mitigated Versions	CP050/CP150: upgrade to 9.90 or later; CP300 7ST85/7ST86: upgrade to 10.00 or later; remaining CP300 models: upgrade to 9.90 or later where available
Exploitation Status	No public exploitation confirmed in reviewed sources; exploitation requires authenticated DIGSI 5 protocol access
Sector Relevance	Energy, transportation systems, critical manufacturing, healthcare, financial services, government facilities

3. Source Review & Confidence

Source	Contribution	Confidence
CISA ICSA-26-174-02	Canonical advisory, affected models, impact, mitigation summary	High
Siemens ProductCERT advisory landing page	Vendor remediation authority and future fix tracking	High when available to asset owners
CVE/Vulners/CVEFeed mirrors	Secondary indexing of CVE-2025-40808 and weakness text	Medium

The core technical claim is well-supported by CISA's advisory text. Public exploitation and proof-of-concept status were not corroborated during this run, so this report avoids claiming active exploitation.

4. Vulnerability Details

Authenticated DIGSI 5 protocol users can upload arbitrary files to affected SIPROTEC 5 devices. CISA states that a malicious configuration file may produce a permanent denial-of-service condition and could potentially lead to code execution. The

practical blast radius depends on whether engineering access is tightly segmented, whether remote maintenance accounts are controlled, and whether relay configuration management is monitored.

5. Attack Scenarios

Scenario	Preconditions	Defender Concern
Compromised engineering workstation	Attacker obtains valid engineering credentials or session access	Uploads malicious configuration and disrupts protection relay availability
Remote maintenance misuse	Vendor or integrator path reaches relay-management zone	Abuse blends with legitimate maintenance traffic unless changes are audited
Aviation / airport power OT pivot	Relay-management network supports airport facilities, hangars, MRO, or airfield power	DoS against protective devices can affect operational resilience even without direct aircraft-system compromise

6. Affected Products and Exposure

Exposure Pattern	Why It Matters	Priority
DIGSI 5 access from broad corporate networks	Increases probability that credential compromise reaches relay configuration interfaces	Critical
Engineering workstations with local admin sprawl	Increases risk of credential theft and unauthorized configuration upload	High
Segmented relay-management zone with MFA and jump hosts	Reduces reachability but still requires patch validation and monitoring	Medium

7. Aviation / Aerospace Sector Impact

Segment	Operational Relevance	Exposure Path	Defender Action
Airports and airfields	Power-distribution reliability supports terminals, lighting, baggage, and airside operations	Facilities OT networks and contractor remote access	Inventory SIPROTEC 5 assets, restrict DIGSI 5 paths, validate firmware
Aerospace manufacturing / MRO	Production lines, test cells, and facility substations may use industrial protection devices	Engineering workstations and integrator support channels	Treat relay-management hosts as tier-0 OT assets
Government / military aviation facilities	Mission availability may depend on resilient power and facility OT	Cross-domain maintenance enclaves	Review privileged access and change-control logs

8. Mitigation and Workarounds

1. Validate whether any listed SIPROTEC 5 models are deployed; do not rely on IT vulnerability scanning alone.
2. Upgrade CP050/CP150 devices to 9.90 or later, CP300 7ST85/7ST86 to 10.00 or later, and other CP300 models to 9.90 or later where applicable.
3. Restrict DIGSI 5 protocol access to dedicated engineering workstations and jump hosts.
4. Enforce named accounts, MFA where technically possible, privileged access review, and maintenance-window approvals.
5. Monitor relay configuration backups and alert on unexpected file/configuration changes.

9. Detection Engineering

9.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
DIGSI 5 connections from non-engineering hosts	Firewall, switch, Zeek, OT sensor	Identify unauthorized management access
Configuration upload or relay-management file transfer	OT IDS, engineering workstation logs, vendor tooling logs	Detect abuse of arbitrary upload path
New authentication from remote-support account	PAM/VPN/Windows logs	Detect credential misuse before relay impact
<pre> title: Siemens SIPROTEC DIGSI5 Management Access From Non Engineering Host status: experimental description: Detects DIGSI 5 or SIPROTEC management traffic initiated by hosts outside the approved engineering workstation set. logsource: category: firewall product: network fields: - src_ip - dest_ip - dest_port - app - action detection: selection_keywords: app contains: - DIGSI - SIPROTEC filter_engineering_subnet: src_ip cidr: - 10.50.20.0/24 condition: selection_keywords and not filter_engineering_subnet level: high DeviceNetworkEvents where Timestamp > ago(30d) where RemoteUrl has_any ("SIPROTEC", "DIGSI") or InitiatingProcessCommandLine has_any ("DIGSI", "SIPROTEC") where not(IPv4IsInRange(LocalIP, "10.50.20.0/24")) project Timestamp, DeviceName, LocalIP, RemoteIP, RemotePort, InitiatingProcessFileName, InitiatingProcessCommandLine </pre>		

10. Threat Hunting

10.1. Hunt Hypothesis

An attacker with access to an engineering workstation or remote support path will perform relay-management activity outside normal maintenance windows before attempting configuration upload.

<pre> DeviceProcessEvents where Timestamp > ago(30d) where ProcessCommandLine has_any ("DIGSI", "SIPROTEC", "relay", "configuration") summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Commands=make_set(ProcessCommandLine, 20) by DeviceName, AccountName order by LastSeen desc </pre>
--

11. MITRE ATT&CK Mapping

Technique	Name	Evidence / Rationale
-----------	------	----------------------

T1190	Exploit Public-Facing Application	Applicable only where DIGSI 5 management is exposed beyond trusted engineering zones
T1078	Valid Accounts	Exploitation requires authenticated access
T1499	Endpoint Denial of Service	Malicious configuration upload can trigger persistent DoS conditions

12. Validation / Lab Testing

No live exploit or device test was performed. Validation completed during this run: CISA advisory review, source corroboration search, renderer QA, and detection/hunt query preservation checks.

13. Recommended Actions Summary

Priority	Owner	Action
Critical	OT asset owner	Inventory affected SIPROTEC 5 models and map DIGSI 5 access paths
High	OT engineering	Apply Siemens-recommended firmware upgrades or allow-list mitigation
High	SOC / OT monitoring	Add DIGSI 5 management access detections and maintenance-window review
Medium	Third-party risk	Confirm integrator remote access cannot reach relay-management networks without approval

14. References

- [1] CISA ICSA-26-174-02: Siemens SIPROTEC 5 Using DIGSI5 Protocol
- [2] Siemens ProductCERT advisory and remediation guidance
- [3] CVE-2025-40808 secondary vulnerability indexes